

IoT Device Reconnaissance to Identify Security Exposures

Tool: Shodan / Nmap

Theory

IoT (Internet of Things) devices such as routers, cameras, and smart appliances are often connected to the internet with default credentials and unpatched firmware, making them easy targets. Shodan is a search engine that indexes publicly exposed devices and their open services across the internet. Nmap is used in the lab to perform the same reconnaissance locally on authorised targets. This experiment uses Shodan only for educational observation and Nmap only on Metasploitable 2 in an isolated lab network.

Steps

1. Open Firefox in Kali Linux and go to <https://www.shodan.io> — Create a free account and log in.
 2. In the Shodan search bar type: default password — Observe the results showing real internet-facing devices that still have default credentials. Note the device types, countries, and open ports shown.
 3. Search for a specific device type. In the search bar type: webcamXP — Shodan lists exposed web cameras. This demonstrates how poorly secured IoT devices are visible to anyone on the internet.
 4. Use a Shodan filter to narrow results by country. Search: country:IN port:23 — This shows devices in India with Telnet open, a common misconfiguration on IoT devices.
 5. Install the Shodan CLI on Kali for command-line access. Run: `pip3 install shodan`
`--break-system-packages` — Then initialise it with your API key from the Shodan account page. Run: `shodan init YOUR_API_KEY`
 6. Use the Shodan CLI to look up information about a specific IP. Run: `shodan host 8.8.8.8` — This shows open ports, services, and location for the given IP address.
 7. Switch to the lab environment. Start Metasploitable 2 on a Host-Only network. Scan for common IoT ports on the target. Run: `nmap -sV -p 23,80,8080,443,554 192.168.56.102` — Note which ports are open and what services are running.
 8. Check for default credentials on web services found on the target. Run: `nmap --script http-default-accounts -p 80 192.168.56.102` — The script reports any services still using known default login combinations.
 9. Save the Nmap scan results for documentation. Run: `nmap -sV -p 23,80,8080 192.168.56.102 -oN iot_scan.txt` — View the saved output. Run: `cat iot_scan.txt`
-

Conclusion

Shodan demonstrated how large numbers of IoT devices are publicly exposed with default credentials and unnecessary open ports. Nmap confirmed similar issues on the lab target. This experiment highlights why changing default passwords, disabling unused services, and keeping firmware updated are essential steps in securing any IoT deployment.